INCIDENT RESPONSE PLAYBOOK

Internship Simple Project 1| Cybersecurity

CODEC TECHNOLOGIES
PREPARED BY: PUSHTI VYAS

Contents

INCIDENT RESPONSE PLAYBOOK 2
SECTION 1: PROJECT OVERVIEW 3
1.1 What is Incident Response? 3
1.2 Why is Incident Response Important in Cybersecurity? 3
1.3 Real-World Relevance 3
i) In Security Operations Centers (SOC) 3
ii) Real-World Breach Examples 4
1.4 Objectives of This Project 4
SECTION 2: INCIDENT RESPONSE FRAMEWORK 4
Phase 1: PREPARATION 5
Phase 2: IDENTIFICATION 5
Phase 3: CONTAINMENT 5
Phase 4: ERADICATION 6
Phase 5: RECOVERY 6
Phase 6: LESSONS LEARNED 6
Visual Summary of NIST IR Framework 6
SECTION 3: INCIDENT RESPONSE PLAN (IRP) 7
3.1 Introduction 7
3.2 Scope 7
3.3 Roles and Responsibilities 7
3.4 Incident Classification 8
3.5 Communication Plan 9
i) Internal Communications 9
ii) External Communications 9
3.6 Tools Used 10
3.7 Escalation Matrix 10
SECTION 4: INCIDENT RESPONSE PLAYBOOKS 11
PLAYBOOK A: MALWARE ATTACK 11
A.1 Description 11
A.2 Indicators of Compromise (IoCs) 11
A.3 Detection Steps 11
A.4 Containment Steps 12
A.5 Eradication Steps 13

A.6 Recovery Steps 13
A.7 Prevention Tips 13
PLAYBOOK B: PHISHING ATTACK 14
B.1 Description 14
B.2 Indicators of Compromise (IoCs) 14
B.3 Detection Steps 14
B.4 Containment Steps 15
B.5 Eradication Steps 16
B.6 Recovery Steps 16
B.7 Prevention Tips 16
PLAYBOOK C: UNAUTHORIZED ACCESS 17
C.1 Description 17
C.2 Indicators of Compromise (IoCs) 17
C.3 Detection Steps 17
C.4 Containment Steps 18
C.5 Eradication Steps 19
C.6 Recovery Steps 19
C.7 Prevention Tips 20

SECTION 1: PROJECT OVERVIEW

1.1 What is Incident Response?

Incident Response (IR) is a structured, organized approach to addressing and managing the aftermath of a cybersecurity attack or data breach. The primary goal is to handle the situation in a way that limits damage, reduces recovery time, and minimizes both financial and reputational impact on the organization.

In simple terms: when something goes wrong in an organization's digital environment — whether it's a virus, a hacker, a data leak, or a phishing attack — the team does not panic and act randomly. Instead, they follow a pre-defined playbook that tells them exactly what to do, who to call, and how to fix it.

An Incident Response plan is like a fire drill for cybersecurity. Just as companies practice what to do when a fire alarm goes off, cybersecurity teams practice and document what to do when a digital attack occurs.

1.2 Why is Incident Response Important in Cybersecurity?

Cyber threats are increasing at an alarming rate. In 2023, the average cost of a data breach globally reached **$4.45 million USD** (IBM Cost of a Data Breach Report, 2023). Without a proper Incident Response plan, organizations risk:

- **Extended downtime** — Systems remain offline for days or weeks
- **Data loss** — Sensitive customer, financial, or health data gets stolen
- **Legal and regulatory penalties** — GDPR, HIPAA, and other laws impose heavy fines
- **Reputation damage** — Customers lose trust in the organization
- **Financial loss** — Business operations are disrupted
- **Uncoordinated chaos** — Teams don't know who is responsible for what

With a proper IR plan, the organization can: - Detect attacks early - Contain damage quickly - Recover faster and more efficiently - Learn from the incident to prevent future ones - Demonstrate compliance with regulations

1.3 Real-World Relevance

In Security Operations Centers (SOC)

Every enterprise SOC has a dedicated Incident Response team. Analysts at Level 1, 2, and 3 follow documented playbooks for every type of incident. Tools like **Splunk**, **IBM QRadar**, **Microsoft Sentinel**, and **CrowdStrike Falcon** generate alerts that trigger these playbooks.

Real-World Breach Examples

Incident	Year	Impact	IR Failure
SolarWinds Supply Chain Attack	2020	18,000+ organizations compromised	Late detection; no containment playbook
Colonial Pipeline Ransomware	2021	$4.4M ransom paid; fuel shortages	No ransomware IR playbook in place
Uber Data Breach	2022	57M user records exposed	IR team was bypassed; covered up
MOVEit Transfer Attack	2023	2,600+ organizations affected	Patch management & IR failure

These incidents show that **having an IR plan isn't optional — it's a business necessity.**

1.4 Objectives of This Project

This project aims to:

1. Understand and document the standard Incident Response lifecycle framework
2. Develop a professional Incident Response Plan (IRP) suitable for a mid-sized organization
3. Create detailed, step-by-step response playbooks for three critical incident types: Malware, Phishing, and Unauthorized Access
4. Design visual diagrams for the IR lifecycle and attack handling workflow
5. Demonstrate the ability to think and act like a real-world SOC analyst
6. Build a project portfolio piece ready for GitHub and academic submission

SECTION 2: INCIDENT RESPONSE FRAMEWORK

This project follows the **NIST SP 800-61 Revision 2** framework — the most widely adopted standard in the industry, published by the National Institute of Standards and Technology (NIST).

Phase 1: PREPARATION

"Getting ready before anything happens."

This is the most critical phase. Everything that makes a team effective during a real incident is built here — before any attack occurs.

What happens in Preparation: - Establishing an Incident Response Team (IRT) with clear roles - Creating and documenting the Incident Response Plan - Deploying security tools: SIEM (Splunk), IDS/IPS, Firewalls, Endpoint Detection - Training staff and running tabletop exercises (practice simulations) - Setting up communication channels (secure emails, phone trees) - Ensuring backups are tested and up to date - Creating asset inventories — knowing what systems exist and what's critical

Why it matters: Teams that skip preparation end up improvising during an actual attack, leading to mistakes, longer downtime, and bigger losses.

Phase 2: IDENTIFICATION

"Detecting that something is wrong."

In this phase, the team determines whether an event is actually a security incident or just a false alarm. Not every alert means an attack — the team must investigate.

What happens in Identification: - Monitoring logs, alerts, and network traffic through SIEM tools - Classifying events as: false positive, true positive, or incident - Determining the type of incident (malware, phishing, DDoS, etc.) - Documenting the initial details: time, affected systems, source IP, affected users - Assigning a severity level (Low / Medium / High / Critical) - Formally declaring an incident and notifying stakeholders

Key question asked: *"Is this a real incident? How severe is it?"*

Phase 3: CONTAINMENT

"Stop the bleeding."

Once an incident is confirmed, the team moves fast to prevent it from spreading to other systems. Think of it like quarantining a sick person to prevent disease spread.

Short-Term Containment: - Isolate affected machines from the network immediately - Block malicious IP addresses and domains at the firewall - Disable compromised user accounts - Preserve evidence (take system images/snapshots) before any cleanup

Long-Term Containment: - Apply temporary fixes and patches - Set up alternative systems for business continuity - Monitor for any signs of attacker persistence

Why it matters: Without containment, a single infected machine can spread malware to hundreds of systems within minutes.

Phase 4: ERADICATION

"Remove the threat completely."

After containment, the actual root cause is identified and completely removed from the environment.

What happens in Eradication: - Remove malware, backdoors, and malicious files - Delete attacker-created accounts and revoke unauthorized access - Patch the vulnerability that allowed the attacker in - Scan all systems for remnants of the attack - Verify that all indicators of compromise (IoCs) have been eliminated

Important: Eradication must be thorough. If even one backdoor remains, the attacker can re-enter.

Phase 5: RECOVERY

"Return to normal operations safely."

Systems are restored and brought back online — but carefully, not all at once.

What happens in Recovery: - Restore systems from clean, verified backups - Re-image compromised systems if needed - Monitor restored systems extra closely for 24–72 hours - Validate that business functions are running normally - Change all passwords and rotate cryptographic keys - Confirm that the attacker can no longer access the environment

Key question: *"Are we safe enough to resume normal operations?"*

Phase 6: LESSONS LEARNED

"Learn from what happened and improve."

This phase is conducted after the incident is fully resolved — typically within 2 weeks. A post-incident review (PIR) meeting is held.

What happens in Lessons Learned: - Document a complete incident timeline - Identify what went well and what failed - Determine root cause of the incident - Update IR playbooks, policies, and procedures - Brief management and relevant stakeholders - File the final Incident Report for compliance/audit purposes

Why it matters: Each incident is a learning opportunity. Organizations that skip this phase repeat the same mistakes.

SECTION 3: INCIDENT RESPONSE PLAN (IRP)

INCIDENT RESPONSE PLAN (IRP)
Prepared By: Pushti Vyas
Version: 1.0
Classification: USE-ONLY
Owner: Information Security Team

3.1 Introduction

This Incident Response Plan (IRP) establishes the procedures and guidelines for detecting, reporting, analyzing, containing, eradicating, and recovering from cybersecurity incidents affecting [Organization Name]'s information systems, networks, data, and personnel.

This plan is developed in alignment with: - **NIST SP 800-61 Rev. 2** – Computer Security Incident Handling Guide - **ISO/IEC 27035** – Information Security Incident Management - **SANS Incident Response Methodology**

The plan applies to all employees, contractors, vendors, and third parties who access, use, or manage organizational IT resources.

3.2 Scope

This plan covers all cybersecurity incidents involving:

- **Information Systems** — Servers, workstations, laptops, mobile devices
- **Network Infrastructure** — Routers, switches, firewalls, VPNs
- **Cloud Environments** — AWS, Azure, Google Cloud deployments
- **Applications** — Web applications, internal tools, SaaS products
- **Data** — Customer PII, financial data, intellectual property, employee records
- **Third-Party Systems** — Vendor systems with access to organizational data

Out of Scope: Physical security incidents (handled by facilities team), non-security IT failures (handled by IT Helpdesk).

3.3 Roles and Responsibilities

Role	Name/Team	Responsibilities
Incident Response Manager (IRM)	[CISO / Security Manager]	Declare incidents, coordinate all phases, communicate with executives, final decisions
SOC Lead Analyst	[SOC Team Lead]	Lead technical investigation, direct containment, oversee analyst work
SOC Analyst (L1/L2/L3)	[Security Analysts]	Monitor alerts, triage events, collect evidences.

Role	Name/Team	Responsibilities
Forensic Investigator	[Digital Forensics Team]	Preserve evidence, conduct deep analysis, chain of custody documentation
IT / System Administrator	[IT Department]	Implement technical containment and recovery actions on systems
Network Administrator	[Network Team]	Block malicious IPs/domains, modify firewall rules, analyze network traffic
Legal Counsel	[Legal Team]	Advise on regulatory obligations, breach notification requirements
HR Representative	[Human Resources]	Handle incidents involving employees, insider threat cases
Communications / PR	[PR Team]	Manage external communications, press releases if required
Executive Sponsor	[CEO / CTO / CISO]	Receive briefings, approve significant decisions (shutting down systems, ransom decisions)

3.4 Incident Classification

All incidents are classified on a four-tier severity scale to ensure appropriate resource allocation and response speed.

Severity Level	Description	Examples	Response Time
P4 – LOW	Minimal impact; isolated event with no data exposure	Single user phishing attempt (no click), minor malware on isolated device	72 hours
P3 – MEDIUM	Moderate impact; limited spread; no confirmed data breach	Malware on 1–5 machines, unauthorized access attempt (failed), suspicious logins	24 hours
P2 – HIGH	Significant impact; active threat; possible data exposure	Active malware spreading across network, confirmed unauthorized access, credential theft	4 hours

Severity Level	Description	Examples	Response Time
P1 – CRITICAL	Severe impact; major data breach; business continuity threatened	Ransomware across environment, confirmed data exfiltration, full system compromise	1 hour (immediate)

3.5 Communication Plan

Internal Communications

Audience	When	Channel	Who Notifies
SOC Team	Immediately on detection	Slack/Teams (secure channel) + phone	L1 Analyst → SOC Lead
IT/Network Teams	Within 30 min of P2/P1	Email + Phone	IRM
CISO / Security Manager	Within 1 hour of P2/P1	Direct phone call	IRM
CEO / Executive Team	For all P1 incidents	Executive briefing	CISO
Legal Team	When data breach suspected	Encrypted email	CISO/IRM
All Employees	If incident affects systems they use	Company-wide email	HR / Communications

External Communications

Audience	Trigger	Timeframe	Owner
Affected customers	Confirmed PII breach	Within 72 hours (GDPR)	Legal + PR
Regulatory bodies (CERT-In, etc.)	Critical breach per regulation	Per applicable law	Legal
Law enforcement	Criminal activity suspected	As appropriate	Legal / CISO
Media / Public	If incident becomes public	Only when necessary	PR Team
Cyber Insurance provider	For P1 incidents	Within 24 hours	CISO

Golden Rule: No public or media statements shall be made without written approval from Legal and the Executive Sponsor.

3.6 Tools Used

Category	Tool	Purpose
SIEM	Splunk Enterprise Security	Log aggregation, correlation, alerting, dashboards
EDR	CrowdStrike Falcon / Microsoft Defender for Endpoint	Endpoint detection, isolation, response
Network Analysis	Wireshark, Zeek (Bro)	Packet capture and network traffic analysis
Vulnerability Scanner	Nessus / OpenVAS	Identify unpatched vulnerabilities
Threat Intelligence	VirusTotal, MISP, AlienVault OTX	IoC lookup, threat intel feeds
Forensics	Autopsy, FTK Imager, Volatility	Disk and memory forensics
Ticketing / Case Management	TheHive / Jira / ServiceNow	Incident tracking and workflow management
Communication	Encrypted Slack / Signal / PGP Email	Secure team communication during incident
Backup & Recovery	Veeam / Acronis	System restore and recovery

3.7 Escalation Matrix

Situation	Escalate To	Method	Timeframe
P4 incident identified	SOC Lead	Ticket + Slack	4 hours
P3 incident confirmed	SOC Lead + IT Admin	Ticket + Email	2 hours
P2 incident confirmed	IRM + CISO	Phone + Email	30 minutes
P1 incident confirmed	IRM + CISO + CEO	Phone (immediately)	15 minutes
Data breach suspected	Legal + Compliance	Encrypted email + phone	30 minutes
Ransomware detected	Entire IRT + Executive Team	Emergency call	Immediate
External attacker confirmed	Law Enforcement + IRM	Through Legal	Per legal advice
Incident not resolved in 4 hrs	Escalate one level higher	Phone	At 4-hour mark

SECTION 4: INCIDENT RESPONSE PLAYBOOKS

PLAYBOOK A: MALWARE ATTACK

PLAYBOOK: MALWARE ATTACK RESPONSE
Type: Malware (Ransomware / Trojan / Worm / Virus)
Severity Range: P2 – P1
Version: 1.0

A.1 Description

Malware (malicious software) is any software intentionally designed to cause harm to a system, network, or user. Types include ransomware (encrypts files and demands payment), trojans (masquerades as legitimate software), worms (self-replicating across networks), spyware (silently collects data), and viruses (attach to files and spread).

Common entry points: - Phishing email attachments or links - Drive-by downloads from malicious websites - Infected USB drives - Exploited vulnerabilities in unpatched software - Supply chain compromises

A.2 Indicators of Compromise (IoCs)

Behavioral IoCs: - Sudden system slowdown, high CPU/memory usage with no obvious cause - Files being renamed with strange extensions (e.g., .locked, .enc, .crypt) - Ransom notes appearing on the desktop or in folders - Antivirus/EDR alerts with unknown process names - Unexpected outbound network connections to unknown IPs - Disabled Task Manager, Registry Editor, or Group Policy - Strange scheduled tasks or startup entries appearing

Technical IoCs: - Unknown processes running in Task Manager (e.g., svchost32.exe, update.exe) - Suspicious registry keys under HKCU\Software\Microsoft\Windows\CurrentVersion\Run - PowerShell or cmd.exe spawning from Office applications (Word, Excel) - Lateral movement via SMB (port 445) or RDP (port 3389) - DNS queries to known malicious domains (check against threat intel feeds) - Large volumes of encrypted traffic to external IPs

A.3 Detection Steps

1. **Receive Alert** — SIEM (Splunk) generates alert based on correlation rule or AV/EDR detection

2. **Verify the Alert** — SOC Analyst L1 reviews the alert; confirm it is a true positive, not a false alarm

3. **Identify Affected Host** — Record the hostname, IP address, MAC address, logged-in user, and department

4. **Check Endpoint** — Review EDR (CrowdStrike) for process tree, parent-child process relationships, and file modifications

5. **Query SIEM** — Run the following Splunk query to check for related events:

```
index=main host="[AFFECTED_HOST]" sourcetype="WinEventLog" earliest=-24h
| stats count by EventCode, Account_Name, Computer
| sort -count
```

6. **Check Network Logs** — Identify any unusual outbound connections, large data transfers, or C2 communication
7. **Search Threat Intel** — Submit suspicious file hashes to VirusTotal; check IPs against AbuseIPDB and MISP
8. **Assign Severity** — Determine if incident is P4 (isolated, low), P3 (limited spread), P2 (active spread), or P1 (ransomware/full compromise)
9. **Open Incident Ticket** — Log in TheHive/ServiceNow with all details; assign to SOC Lead
10. **Notify IRM** — Immediately notify Incident Response Manager if severity is P2 or P1

A.4 Containment Steps

Immediate Actions (within 30 minutes):

1. **Isolate Affected System(s)** — Disconnect from network (pull Ethernet cable or disable Wi-Fi)
    - If using EDR: use CrowdStrike's "Network Contain" feature to isolate remotely
    - Do NOT power off the machine (preserves volatile memory for forensics)
2. **Disable Compromised Accounts** — In Active Directory, disable any user accounts found in malware process context
3. **Block Malicious IPs/Domains** — Add attacker C2 IPs and domains to firewall block list and DNS sinkhole
4. **Preserve Evidence** — Before any cleanup, capture memory dump using Volatility or WinPMem:

```
winpmem_mini_x64_rc2.exe memdump.raw
```

5. **Take Disk Image** — Use FTK Imager to capture forensic disk image of the affected machine
6. **Notify All Admins** — Alert IT and Network teams to watch for lateral movement signs on adjacent systems
7. **Check for Spread** — Run Splunk query to identify other hosts that communicated with infected machine:

```
index=network dest_ip="[INFECTED_IP]" OR src_ip="[INFECTED_IP]"
| stats count by src_ip, dest_ip
```

Long-Term Containment (if spread is suspected):

8. Segment affected network VLAN from the rest of the environment
9. Deploy honeypot or monitoring on network segments adjacent to infected systems
10. Reset all shared credentials that the affected user had access to

A.5 Eradication Steps

1. **Identify Root Cause** — Determine how the malware entered: phishing email? exploit? USB?
2. **Remove Malware** — Run full scan using offline AV scanner (boot from clean USB with updated definitions)
3. **Delete Malicious Artifacts** — Remove all malicious files, registry keys, and scheduled tasks identified
4. **Remove Persistence Mechanisms** — Check and clean:
   - HKCU\Software\Microsoft\Windows\CurrentVersion\Run
   - C:\Users\[user]\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup
   - Scheduled tasks in Task Scheduler
5. **Patch the Vulnerability** — Apply the security patch that the malware exploited
6. **Update Threat Intelligence** — Add new IoCs (hashes, IPs, domains) to SIEM correlation rules and threat feeds
7. **Scan Adjacent Systems** — Run scans on all systems in the same subnet to confirm no spread
8. **Verify Clean State** — Confirm with EDR that no malicious processes remain

A.6 Recovery Steps

1. **Restore from Backup** — If system is heavily compromised, re-image from last known clean backup
2. **Verify Backup Integrity** — Confirm backup was taken before the infection date
3. **Re-join to Domain** — After re-imaging, re-join the machine to Active Directory
4. **Install Security Updates** — Apply all pending OS and software patches
5. **Reset Credentials** — Force password reset for all accounts used on the infected machine
6. **Monitor Closely** — Place system under enhanced monitoring in Splunk for 72 hours post-recovery
7. **Phased Return to Production** — Test in isolated environment first; return to production only after verification
8. **Confirm Business Continuity** — Verify the user/team affected can resume normal operations

A.7 Prevention Tips

- Deploy and keep Endpoint Detection & Response (EDR) updated on all devices
- Enable application whitelisting — only allow approved software to execute
- Implement email filtering to block malicious attachments (sandbox analysis)
- Disable macros in Microsoft Office by default; use Group Policy to enforce
- Apply the Principle of Least Privilege — users should not have admin rights

- Maintain tested, offline backups following the 3-2-1 backup rule
- Patch management: critical patches applied within 48 hours of release
- Regular security awareness training focused on recognizing suspicious files
- Use network segmentation to prevent lateral movement

PLAYBOOK B: PHISHING ATTACK

PLAYBOOK: PHISHING ATTACK RESPONSE
Type: Email Phishing / Spear Phishing / Vishing
Severity Range: P4 – P2
Version: 1.0

B.1 Description

Phishing is a social engineering attack where attackers send fraudulent emails, messages, or create fake websites to trick users into revealing credentials, clicking malicious links, or downloading malware. Spear phishing is a targeted version directed at specific individuals (executives, finance teams). Vishing is voice phishing (phone calls).

Phishing goals typically include: - Credential harvesting (username/password theft) - Malware delivery via malicious attachment - Business Email Compromise (BEC) for financial fraud - Gaining initial access to the network

B.2 Indicators of Compromise (IoCs)

Email-Level IoCs: - Sender domain spoofing (e.g., support@paypa1.com instead of paypal.com) - Mismatched Reply-To address and From address - Generic greetings ("Dear Customer") in supposedly personalized emails - Urgency language: "Act immediately", "Your account will be suspended" - Suspicious attachments: .exe, .vbs, .js, .iso, .lnk, .docm, .xlsm - URLs that don't match displayed link text (hover to check) - Links to newly registered domains (< 30 days old) - Emails failing SPF, DKIM, or DMARC checks

User/System-Level IoCs: - User reports receiving suspicious email - Multiple failed login attempts from unknown locations - Successful login from unusual geographic location or IP - Browser process downloading files unexpectedly - User's email account forwarding emails to external address (BEC indicator) - Credential use from two different countries within minutes (impossible travel)

B.3 Detection Steps

1. **User Reports Phishing** — User submits suspicious email via "Report Phishing" button (Outlook add-in) or IT helpdesk ticket

2. **Automated Detection** — Email gateway (Proofpoint/Mimecast) or SIEM alert flags suspicious email patterns

3. **Retrieve the Email** — SOC Analyst obtains the raw email headers and body for analysis

4. **Analyze Email Headers** — Check originating IP, mail server path, SPF/DKIM/DMARC results:
    - Use MXToolbox or Google Admin Toolbox to analyze headers
    - Check if from domain passes SPF: dig TXT [domain]
5. **Analyze Embedded URLs** — Extract URLs and analyze without clicking:
    - Use URLScan.io to scan URLs safely
    - Check domain age on whois.domaintools.com
    - Submit to VirusTotal for reputation check
6. **Analyze Attachments** — Upload attachment to VirusTotal or detonate in sandbox (Any.run, Cuckoo Sandbox)
7. **Determine Scope** — Query mail gateway logs to find how many users received the same email:

```
Search mail logs for: Subject:"[PHISHING SUBJECT]" OR From:"[SENDER DOMAIN]"
```

8. **Check If Any User Clicked** — Check proxy/web filter logs for users who visited the phishing URL
9. **Check If Credentials Were Entered** — Review failed/successful authentication logs for affected users
10. **Assign Severity:**
    - Nobody clicked → P4 Low
    - Someone clicked but no credentials entered → P3 Medium
    - Credentials entered → P2 High
    - Credentials used + account accessed → P2/P1

B.4 Containment Steps

If nobody clicked: 1. Delete the phishing email from all user inboxes using mail admin tools (Exchange Admin Center / Google Workspace Admin) 2. Block sender domain at email gateway 3. Notify all recipients with a warning

If user clicked the link: 1. Isolate the user's machine from the network immediately 2. Block the phishing URL at the web proxy/firewall for all users 3. Reset the user's password immediately (if credentials may have been entered) 4. Enable MFA immediately on the account if not already enabled 5. Revoke active sessions and tokens for the compromised account 6. Review the user's sent items, inbox rules, and forwarding rules for BEC signs

If credentials were compromised: 1. Disable the affected user account immediately in Active Directory 2. Alert IT admin to check for any changes made using the compromised account 3. Review Active Directory logs for new accounts, group changes, or privilege escalation 4. Check if attackers logged in and accessed any sensitive systems or data.

B.5 Eradication Steps

1. **Remove All Copies of the Phishing Email** — Use admin tools to purge from all mailboxes
2. **Block All IoCs** — Block phishing domain, URL, sender IP at all perimeter controls
3. **Add to Threat Intel Feed** — Submit phishing domain, URL, and email hash to MISP/organizational threat intel
4. **Update Email Gateway Rules** — Create filter rules to block future emails from this domain/sender pattern
5. **Scan for Malware** — If user clicked an attachment, treat as malware incident and run full eradication per Playbook A
6. **Review Account for Persistence** — Check compromised account for:
    - Newly created inbox rules
    - OAuth app permissions granted
    - Forwarding addresses added
    - Devices enrolled during attack window
7. **Remove Malicious OAuth Apps** — If attacker authorized an app via OAuth consent, revoke access

B.6 Recovery Steps

1. **Re-enable Account** — After full password reset and MFA enforcement, re-enable the user account
2. **Restore Changed Settings** — Remove any inbox rules, forwarding settings, or permissions added by attacker
3. **Notify Affected User** — Brief the user on what happened and provide guidance
4. **Verify No Data Exfiltration** — Review DLP logs and cloud storage access during the attack window
5. **Monitor Account** — Place account under enhanced monitoring in SIEM for 30 days
6. **Send Organization-Wide Phishing Alert** — Send sanitized advisory to all staff to stay vigilant

B.7 Prevention Tips

- Implement DMARC, DKIM, and SPF records for all organizational domains
- Deploy an email security gateway with sandbox analysis (Proofpoint, Mimecast)
- Enable multi-factor authentication (MFA) on ALL accounts — especially email and VPN
- Add “Report Phishing” button to Outlook/Gmail for easy user reporting
- Conduct regular simulated phishing exercises using GoPhish or KnowBe4
- Train users: check sender address, hover before clicking links, don’t download unexpected attachments
- Enable Conditional Access Policies — block logins from suspicious geographies
- Use password managers — users won’t re-enter passwords on fake sites
- Implement web filtering to block access to newly registered and malicious domains

PLAYBOOK C: UNAUTHORIZED ACCESS

PLAYBOOK: UNAUTHORIZED ACCESS RESPONSE
Type: Account Compromise / Insider Threat / Brute Force
Severity Range: P3 – P1
Version: 1.0

C.1 Description

Unauthorized access occurs when an individual gains access to systems, networks, or data without proper authorization. This includes external attackers who have obtained credentials, insiders misusing their privileges, brute-force attacks cracking passwords, or attackers escalating their privileges within a system.

Types of unauthorized access: - **External account compromise** — attacker obtained valid credentials via phishing or credential stuffing - **Brute force / Password spraying** — attacker tries many passwords systematically - **Insider threat** — employee accesses data beyond their job role - **Privilege escalation** — attacker with limited access gains admin/root privileges - **Session hijacking** — attacker steals valid session cookies

C.2 Indicators of Compromise (IoCs)

- Multiple failed login attempts from the same IP in a short time (brute force)
- Successful login after many failures (brute force success)
- Login from unusual geographic location or at unusual hours (e.g., 3 AM, foreign country)
- Impossible travel: same account logged in from two countries within minutes
- Access to sensitive files or databases the user has never accessed before
- Large volume of data downloaded or accessed in a short period
- New privileged account created without change ticket
- Existing account suddenly added to Domain Admins or admin groups
- Modification of audit/log settings (attacker trying to hide tracks)
- Access attempts to restricted directories or systems
- VPN login from previously unseen IP with valid credentials

C.3 Detection Steps

1. **SIEM Alert Triggered** — Splunk correlation rule fires on multiple failed logins or anomalous behavior:

```
index=windows_security EventCode=4625
| stats count by Account_Name, src_ip
| where count > 10
| sort -count
```

2. **Review Windows Security Events** — Key Event IDs:
    - 4625 — Failed logon attempt
    - 4624 — Successful logon

    - 4720 — New user account created
    - 4728/4732/4756 — User added to privileged group
    - 4648 — Logon using explicit credentials
    - 4776 — Domain controller credential validation
3. **Identify Affected Account** — Record the username, account type, and what systems they have access to
4. **Determine Access Method** — Was it VPN? RDP? Web application? SSH? Direct console?
5. **Check Source IP** — Look up the source IP on AbuseIPDB, threat intel feeds; determine if internal or external
6. **Map Access Timeline** — Build a timeline of every action performed by the account during the suspected unauthorized session
7. **Review Data Accessed** — Check DLP/file access logs to determine what data was viewed, downloaded, or modified
8. **Assess Intent** — Is this an external attacker? A disgruntled employee? An accidental access?
9. **Classify Severity** — Assign severity based on sensitivity of data accessed and extent of access
10. **Engage HR if Insider Threat** — If the access appears to be from a legitimate user acting maliciously, involve HR and Legal immediately

C.4 Containment Steps

For External Attacker (Compromised Credentials):

1. **Disable Compromised Account** immediately in Active Directory / LDAP
2. **Force Sign-out** from all active sessions (Azure AD: Revoke Sessions; on-prem: kill Kerberos tickets)
3. **Block Source IP** at firewall and WAF
4. **Change Account Password** — Require password reset before account can be re-enabled
5. **Enable/Enforce MFA** — Ensure MFA is active before account restoration
6. **Identify Lateral Movement** — Run SIEM query to check if attacker accessed other systems using the compromised account
7. **Check for Persistence** — Look for new accounts created, scheduled tasks added, backdoors installed

For Insider Threat:

1. Do NOT immediately disable account (may alert the insider)
2. Coordinate with HR and Legal before taking action
3. Enable enhanced monitoring/logging on the account

4. Quietly preserve all evidence before confronting the individual
5. Follow HR and Legal protocols for investigation and disciplinary action

For Brute Force (Account Not Yet Compromised):

1. Block the attacking IP at the firewall
2. Implement account lockout policy (lock after 5 failed attempts)
3. Add CAPTCHA to login pages
4. Enable geo-blocking if attacks originate from unexpected regions

C.5 Eradication Steps

1. **Remove Attacker Persistence** — Delete any backdoor accounts, web shells, SSH keys, or VPN certificates created by the attacker
2. **Audit Privileged Groups** — Review membership of Domain Admins, Local Admins, and other privileged groups; remove unauthorized additions
3. **Revoke Suspicious Tokens** — Invalidate all API keys, OAuth tokens, and certificates that may have been accessed
4. **Review and Revert Changes** — Identify any configuration changes made by the attacker and revert them
5. **Scan for Installed Tools** — Check for attacker tools like netcat, Mimikatz, cobalt strike beacons, or remote access tools
6. **Check for Exfiltration** — Review DLP and proxy logs for large uploads to external sites; check cloud storage sync logs
7. **Patch Exploited Vulnerability** — If access was gained through a vulnerability (e.g., exposed RDP, unpatched VPN), patch it immediately
8. **Conduct Password Audit** — Force password reset for all accounts the compromised account had access to

C.6 Recovery Steps

1. **Re-enable Account with New Credentials** — Only after MFA is enforced and all persistence removed
2. **Notify Affected User** — Brief the user on what happened (unless insider threat investigation is ongoing)
3. **Monitor for Re-entry Attempts** — Watch for the same attacker trying different accounts or methods
4. **Restore Modified Data** — If attacker modified files or configurations, restore from backup
5. **Conduct Privileged Access Review** — Review all privileged accounts; apply Principle of Least Privilege
6. **Implement Privileged Access Workstations (PAW)** — For admin accounts, restrict from where they can log in
7. **Brief Management** — Provide executive summary of what was accessed, what data may have been affected, and remediation taken
8. **Regulatory Notification** — If personal data was accessed, consult Legal on notification obligations (GDPR, HIPAA, etc.)

C.7 Prevention Tips

- Enforce multi-factor authentication (MFA) on all external-facing systems and VPN
- Implement Privileged Access Management (PAM) solutions (CyberArk, BeyondTrust)
- Apply Principle of Least Privilege — users only have access to what they need
- Enable account lockout policies and login anomaly alerts
- Use Conditional Access: block logins from Tor, VPNs, and unexpected geographies
- Implement Zero Trust Architecture — verify every access request continuously
- Conduct quarterly access reviews — remove stale accounts and excess permissions
- Monitor Dark Web credential dumps for organizational email addresses (Have I Been Pwned, SpyCloud)
- Deploy User and Entity Behavior Analytics (UEBA) to detect anomalous access patterns
- Disable RDP and SSH on systems that don't need it; use jump servers/bastion hosts

OVERVIEW

Cybersecurity incidents such as malware attacks, phishing campaigns, and unauthorized access breaches are increasing in frequency and sophistication. Organizations without structured Incident Response (IR) plans suffer significantly greater financial losses and reputational damage compared to those with formal IR processes in place.

This project presents a comprehensive Incident Response Playbook designed for implementation in a real-world organizational environment. The playbook is developed in alignment with the NIST SP 800-61 Revision 2 framework and covers all six phases of the incident response lifecycle: Preparation, Identification, Containment, Eradication, Recovery, and Lessons Learned.

The project includes a formal Incident Response Plan (IRP) defining organizational roles, responsibilities, incident classification criteria, escalation matrices, and communication protocols. Three detailed, step-by-step response playbooks are developed for the most common and critical incident types: Malware Attack, Phishing Attack, and Unauthorized Access.

Additionally, the project includes incident flow diagrams, a complete roles and responsibilities framework, tooling recommendations including SIEM-based detection using Splunk, and prevention strategies for each incident type.

The outcome is a complete, professional-grade IR resource that can be adapted and deployed by security teams in mid-sized organizations, demonstrating both the technical depth and operational thinking required in modern Security Operations Centers (SOC).

CONCLUSION

This project successfully developed a comprehensive Incident Response Playbook that is applicable to real-world organizational cybersecurity operations. Through this work, the following objectives were achieved:

A complete understanding of the NIST SP 800-61 Incident Response Framework was gained and documented, providing a structured approach to handling cybersecurity incidents through six well-defined phases.

A professional Incident Response Plan was created, establishing clear organizational roles and responsibilities, incident classification criteria, escalation paths, and communication protocols — elements that form the backbone of any functional security operations team.

Three detailed playbooks were developed for the most prevalent incident types in the industry: Malware Attacks, Phishing Attacks, and Unauthorized Access incidents. Each playbook provides precise, actionable steps for detection, containment, eradication, recovery, and prevention.

The project also demonstrates the importance of using industry-standard security tools such as Splunk SIEM, CrowdStrike EDR, and threat intelligence platforms in day-to-day incident handling.

This project reinforced that Incident Response is not merely a technical activity — it is a carefully orchestrated organizational process that requires clear communication, defined authority, documented procedures, and continuous improvement. Organizations that invest in mature IR capabilities suffer significantly less damage from cybersecurity events than those that respond reactively.

As a takeaway from this internship, the experience has built a strong foundation for a career in cybersecurity, particularly in SOC operations, threat detection, and incident handling — some of the most in-demand roles in the industry today.

REFERENCES

1. NIST Special Publication 800-61 Revision 2 — *Computer Security Incident Handling Guide*, National Institute of Standards and Technology (2012). Available: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf

2. MITRE ATT&CK Framework — *Adversarial Tactics, Techniques, and Common Knowledge*. Available: https://attack.mitre.org/

3. IBM Security — *Cost of a Data Breach Report 2023*. Available: https://www.ibm.com/security/data-breach

4. ISO/IEC 27035-1:2023 — *Information technology — Information security incident management*.

5. Splunk Inc. — *Security Information and Event Management (SIEM) Documentation*. Available: https://docs.splunk.com/Documentation/ES

6. CISA — *Incident Response Recommendations and Best Practices for IT and OT Environments* (2023). Available: https://www.cisa.gov/

7. OWASP Foundation — *OWASP Top 10 Security Risks*. Available: https://owasp.org/www-project-top-ten/